



VOXXED DAYS 2018
LUXEMBOURG

EXCELLIUM

Your first call when it comes to IT and security



Handle authorization security issues with testing automation

Dominique Righetto

@righettod

#automate_authz_testing



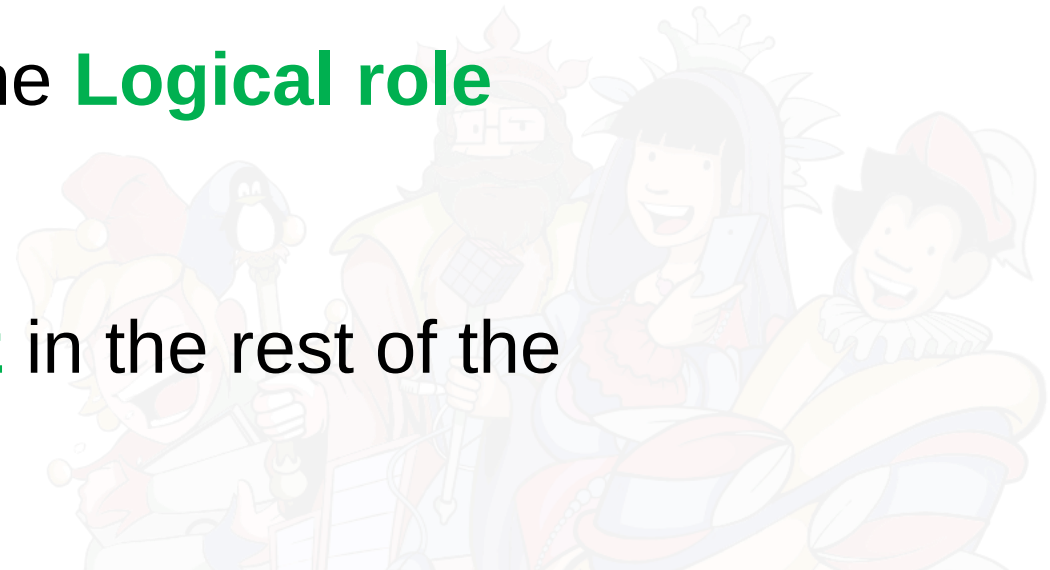
#voxxed_lu



What is an authorization?

- Characterize the access to a resource.
- Composed by several elements often named **Dimensions**.
- Dimensions often used are the **Feature** and the **Logical role**.
- Sometimes a **Data** dimension is used to filter access at data level.
- Will focus here on the **Feature** and the **Logical role** dimensions.

❗ **Authorization** will be named **Authz** in the rest of the presentation.



Authz matrix?

Features \ Logical roles	ANONYMOUS	BASIC	ADMIN
<i>ReadSingleMessage</i>	Grant	Grant	Grant
<i>ReadAllMessages</i>	Grant	Grant	Grant
<i>CreateMessage</i>	Deny	Grant	Grant
<i>DeleteMessage</i>	Deny	Deny	Grant

One feature **x** One logical role = One Authz



List of features **x** List of logical roles = Authz matrix

Issues at Authz level? Consequences?

- Illegal access to a resource with create, read or modify operations.
- Real life impact, do you feel comfortable if:
 - Bank: I can access to your account? Your Credit card?
 - Healthcare: I can access to your medical profile?
 - Mobile: I can access to all your phone Call/SMS with content details?
 - Exchange: I can access to all your private and professional emails?
- Authz issues can lead to **data breaches!**

Authz issues occurs often?

OWASP Top 10 - 2017

A1:2017-Injection

A2:2017-Broken Authentication

A3:2017-Sensitive Data Exposure

A4:2017-XML External Entities (XXE) [NEW]

A5:2017-Broken Access Control [Merged]

A6:2017-Security Misconfiguration

A7:2017-Cross-Site Scripting (XSS)

A8:2017-Insecure Deserialization [NEW, Community]

A9:2017-Using Components with Known Vulnerabilities

A10:2017-Insufficient Logging&Monitoring [NEW,Comm.]

The main cause of healthcare data breaches in March 2018 was unauthorized access/disclosure incidents. 14 incidents were reported, with theft/loss incidents the second main cause with 9 incidents, followed by hacking/IT incidents with 5 breaches reported.

Causes of Healthcare Data Breaches (March 2018)



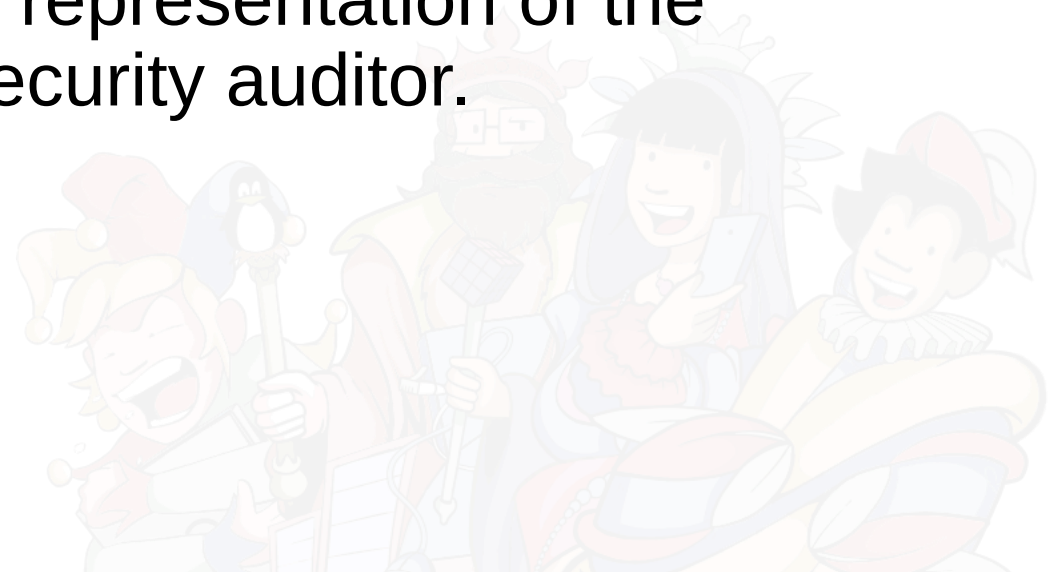
<https://www.hipaajournal.com/march-2018-healthcare-data-breaches/>

Why does Authz issues happen often?

- Hard to define a stable Authz matrix (**Features** x **Logical roles**) on the application life time (new feature, teammates change...).
- Vulnerability scanner, Web Application Firewall, Intrusion Detection System... Can't help here because they can't identify a lawful from an unlawful access → **Stream is legit!**
- Most Authz matrix are tested manually by functional test team, it's hard to test all combinations (time-consuming & mental tiredness) before every release, moreover in Agile/CD project...

Why does Authz issues happen often?

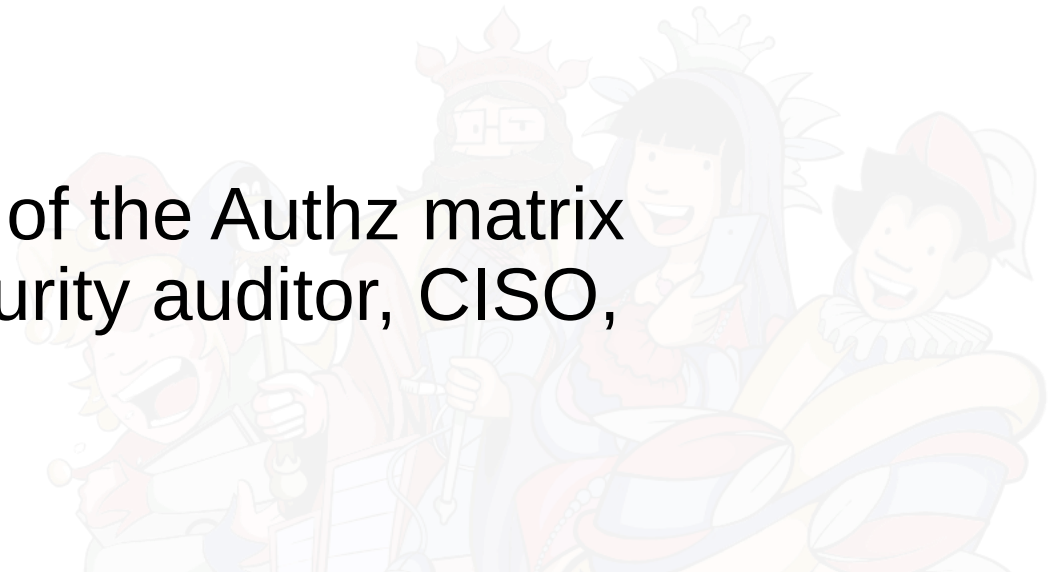
- With time, Authz matrix loss the sync with the real Authz matrix implemented in the application, moreover in maintenance life phase.
- Hard to quickly provide an up-to-date representation of the Authz matrix to an external/internal security auditor.





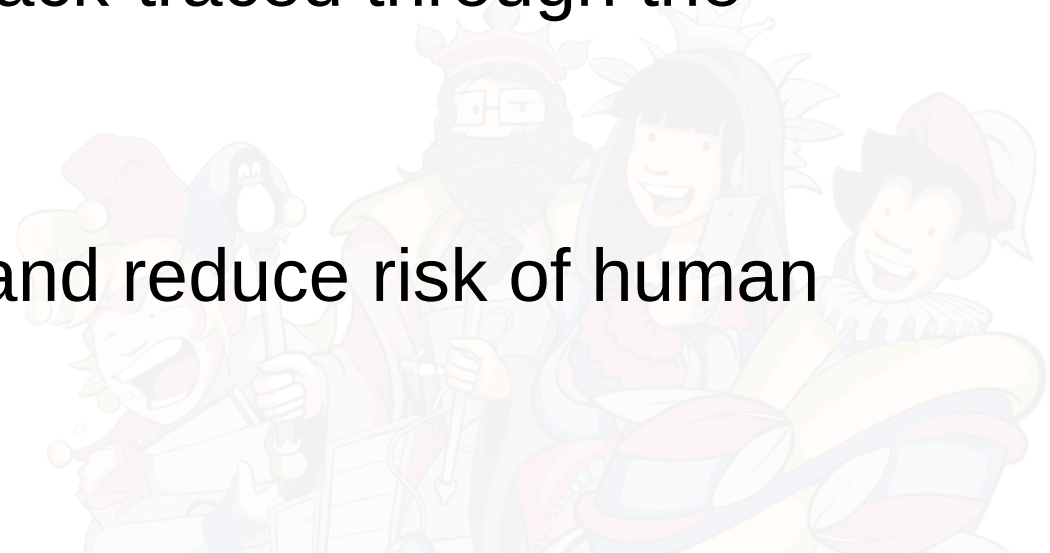
Why leverage Authz testing automation?

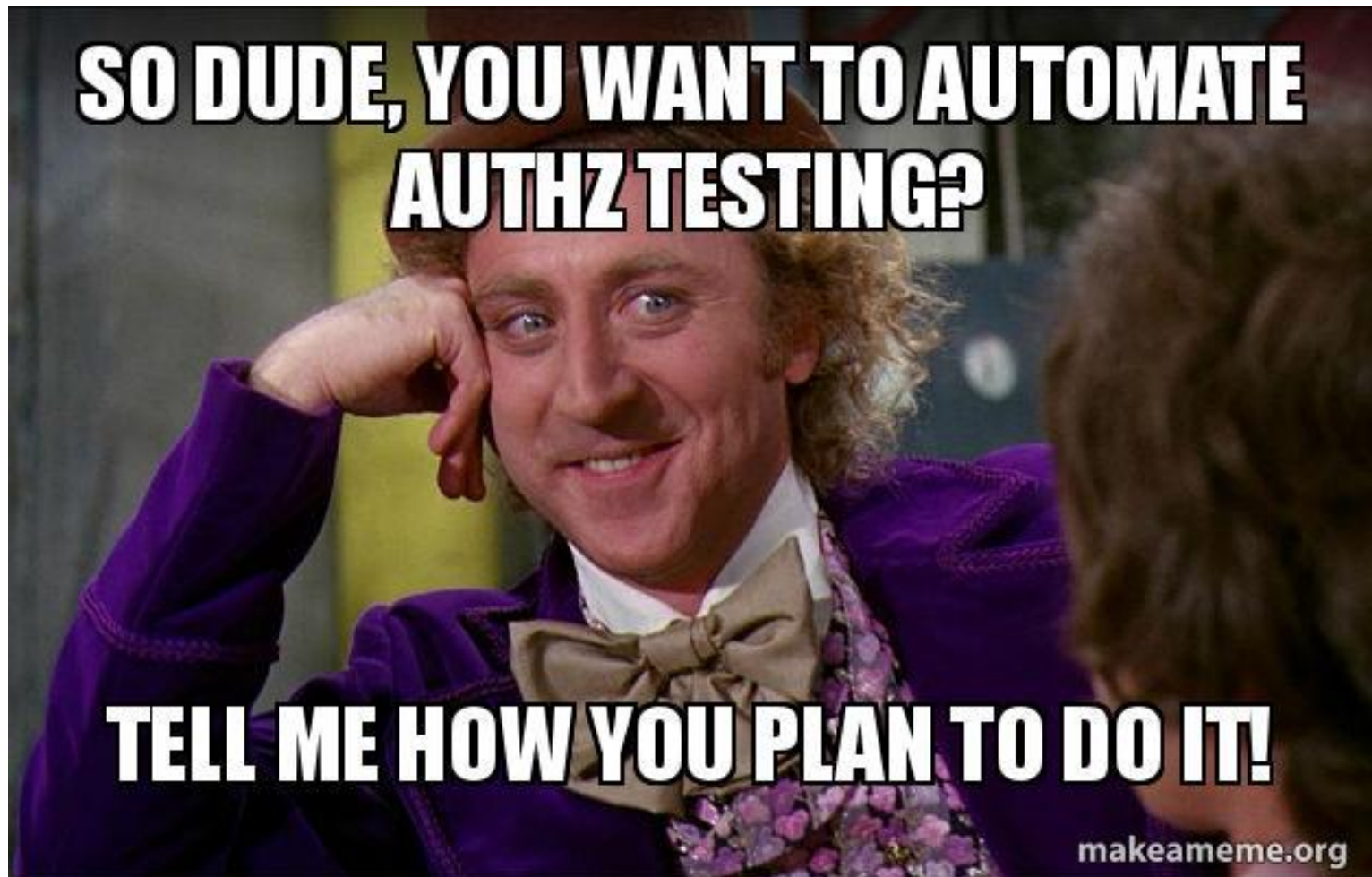
- Continuously ensure that the Authz matrix is in sync with its implementation in the application → **Spot desync quickly!**
- Tests all combinations of the Authz matrix at every Authz matrix test round.
- Be able to generate a representation of the Authz matrix according to the target recipient: Security auditor, CISO, security architect...



Why leverage Authz testing automation?

- Versioning of the Authz matrix with the application code in the SCM: Authz matrix become an asset of the project code baseline.
- Any update on Authz matrix can be back-traced through the SCM log history.
- Gain time in Authz matrix test round and reduce risk of human error during manual testing.





Authz testing: Context

- I will show an example of approach for an application exposing a REST API but the concepts/codes shown can be used for others application types.
- The sample REST API use JSON Web Token to hold authentication.
- Why have I choose a REST API application types for the proposed approach?
 - The application which I meet, expose very often a REST (like) API .
 - It's the most popular application topology meet today in the context of Single Page Application or Micro Services based system.

Authz testing: Guidelines

- Represent the Authz matrix in a pivot file that will allow us to derivate it in different others representations (HTML, Excel...).
- Tests cases will use this pivot file to determine each test context and expected behaviour.
- Test code will be reusable for other projects/technologies.
- Test code will be simple and use standard API/framework in order to:
 - Be integrated in popular IDE and Continuous Integration Platform.
 - Generate test reports in a format already used by dev team.

Authz testing: Overview



Representation of the
Authz matrix



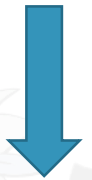
Pivot file



Authz test cases

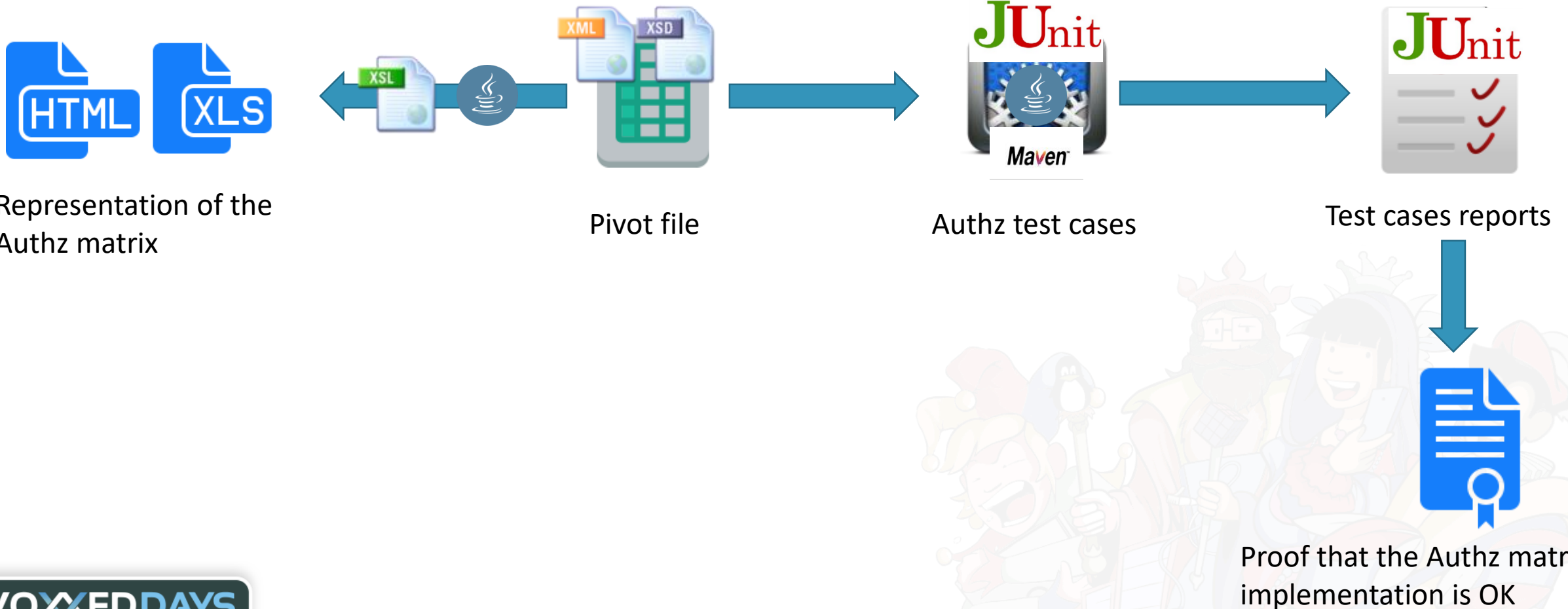


Test cases reports



Proof that the Authz matrix
implementation is OK

Authz testing: Toolbox



Authz testing: Pivot file

authorization-matrix.xml ✕

```
1  <?xml version="1.0" encoding="UTF-8"?>
2  <?xml-stylesheet type="text/xsl" href="authorization-matrix.xsl"?>
3  <!--
4
5      This file materialize the authorization matrix for the different services exposed by the system.
6
7      It will be used by the tests as a input sources for the different tests cases:
8      1) Evaluate legitimate access and is correct implementation
9      2) Identify not legitimate access (authorization definition issue on service implementation)
10
11      The "name" attribute is used for identify uniquely a SERVICE or a ROLE.
12
13  -->
14  <authorization-matrix>
15
16      <!-- Describe the possible logical roles used in the system, is used here to provide a list+explanation of the different roles (authorization level) -->
17      <roles>...
21      </roles>
22
23      <!-- List and describe the available services exposed by the system and the associated logical role(s) that can call them -->
24      <services>...
42      </services>
43
44      <!-- Provide a test payload for each service if needed -->
45      <services-testing>...
60      </services-testing>
61
62  </authorization-matrix>
```



Authz testing: Pivot file example

```
<!-- Describe the possible logical roles used in the system, is used here to provide a list+explanation of the different roles (authorization level) -->
<roles>
  <role name="ANONYMOUS" description="Indicate that no authorization is needed"/>
  <role name="BASIC" description="Role affected to a standard user (lowest access right just above anonymous)"/>
  <role name="ADMIN" description="Role affected to a administrator user (highest access right)"/>
</roles>

<!-- List and describe the available services exposed by the system and the associated logical role(s) that can call them -->
<services>
  <service name="ReadSingleMessage" uri="/{messageId}" http-method="GET" http-response-code-for-access-allowed="200" http-response-code-for-access-denied="403">
    <role name="ANONYMOUS"/>
    <role name="BASIC"/>
    <role name="ADMIN"/>
  </service>
  <service name="ReadAllMessages" uri="/" http-method="GET" http-response-code-for-access-allowed="200" http-response-code-for-access-denied="403">
    <role name="ANONYMOUS"/>
    <role name="BASIC"/>
    <role name="ADMIN"/>
  </service>
  <service name="CreateMessage" uri="/" http-method="PUT" http-response-code-for-access-allowed="200" http-response-code-for-access-denied="403">
    <role name="BASIC"/>
    <role name="ADMIN"/>
  </service>
  <service name="DeleteMessage" uri="/{messageId}" http-method="DELETE" http-response-code-for-access-allowed="200" http-response-code-for-access-denied="403">
    <role name="ADMIN"/>
  </service>
</services>
```



Authz testing: Pivot file example

```
<!-- Provide a test payload for each service if needed -->
<services-testing>
  <service name="ReadSingleMessage">
    <!--
    It's also possible to specify a full set of URL parameters
    like for example:
    0/value1/value2/25
    -->
    <payload location="URL">0</payload>
  </service>
  <service name="ReadAllMessages">
    <payload/>
  </service>
  <service name="CreateMessage">
    <payload content-type="application/json" location="BODY">{"content":"test"}</payload>
  </service>
  <service name="DeleteMessage">
    <payload location="URL">0</payload>
  </service>
</services-testing>
```



Authz testing: Tests example

```
/**
 * Test access to the services from a anonymous user.
 */
@Test
public void testAccessUsingAnonymousUserPointOfView() {
    //Run the tests - No access token here
    List<String> errors = executeTestWithPointOfView(SecurityRole.ANONYMOUS, accessToken: null);
    //Verify the test results
    Assert.assertEquals( message: "Access issues detected using the ANONYMOUS USER point of view:\n" + formatErrorsList(errors), expected: 0, errors.size());
}

/**
 * Test access to the services from a basic user.
 *
 * @throws Exception If any errors occurs
 */
@Test
public void testAccessUsingBasicUserPointOfView() throws Exception {
    //Get access token representing the authorization for the associated point of view
    String accessToken = generateTestCaseAccessToken( login: "basic", SecurityRole.BASIC);
    //Run the tests
    List<String> errors = executeTestWithPointOfView(SecurityRole.BASIC, accessToken);
    //Verify the test results
    Assert.assertEquals( message: "Access issues detected using the BASIC USER point of view:\n " + formatErrorsList(errors), expected: 0, errors.size());
}
```



Authz testing: Tests run example no issue

```
[INFO] --- maven-failsafe-plugin:2.20.1:integration-test (default) @ demo ---
[INFO] -----
[INFO] T E S T S
[INFO] -----
[INFO] Running eu.righettod.pocauthztesting.AuthorizationMatrixIT
[INFO] - Initializing Spring FrameworkServlet 'dispatcherServlet'
[INFO] - FrameworkServlet 'dispatcherServlet': initialization started
[INFO] - FrameworkServlet 'dispatcherServlet': initialization completed in 32 ms
[INFO] Tests run: 3, Failures: 0, Errors: 0, Skipped: 0, Time elapsed: 1.905 s - in eu.righettod.pocauthztesting.AuthorizationMatrixIT
[INFO] Results:
[INFO] Tests run: 3, Failures: 0, Errors: 0, Skipped: 0
```

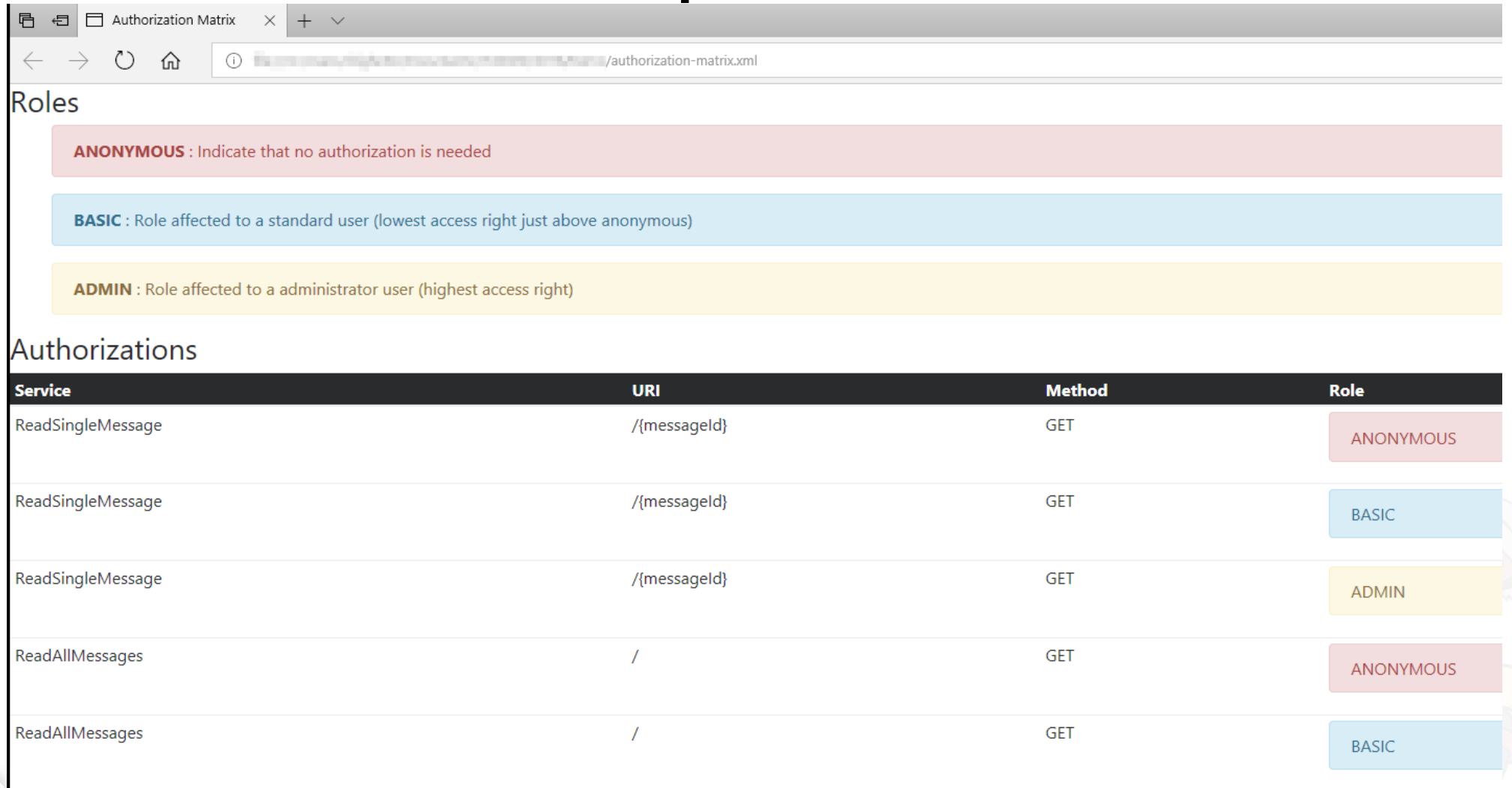


Authz testing: Tests run example with issues

```
[INFO]
[INFO] --- maven-failsafe-plugin:2.20.1:integration-test (default) @ demo ---
[INFO]
[INFO] -----
[INFO] T E S T S
[INFO] -----
[INFO] Running eu.righettod.pocauthztesting.AuthorizationMatrixIT
[INFO] - Initializing Spring FrameworkServlet 'dispatcherServlet'
[INFO] - FrameworkServlet 'dispatcherServlet': initialization started
[INFO] - FrameworkServlet 'dispatcherServlet': initialization completed in 15 ms
[ERROR] Tests run: 3, Failures: 1, Errors: 0, Skipped: 0, Time elapsed: 2.016 s <<< FAILURE! - in eu.righettod.pocauthztesting.AuthorizationMatrixIT
[ERROR] testAccessUsingBasicUserPointOfView(eu.righettod.pocauthztesting.AuthorizationMatrixIT) Time elapsed: 0.062 s <<< FAILURE!
java.lang.AssertionError:
Access issues detected using the BASIC USER point of view:
The service 'DeleteMessage' when called with POV 'BASIC' return a response code 200 that is not the expected one (403 expected).
expected:<0> but was:<1>
    at eu.righettod.pocauthztesting.AuthorizationMatrixIT.testAccessUsingBasicUserPointOfView(AuthorizationMatrixIT.java:87)

[INFO]
[INFO] Results:
[INFO]
[ERROR] Failures:
[ERROR]   AuthorizationMatrixIT.testAccessUsingBasicUserPointOfView:87 Access issues detected using the BASIC USER point of view:
The service 'DeleteMessage' when called with POV 'BASIC' return a response code 200 that is not the expected one (403 expected).
expected:<0> but was:<1>
[INFO]
[ERROR] Tests run: 3, Failures: 1, Errors: 0, Skipped: 0
```

Authz matrix: HTML representation



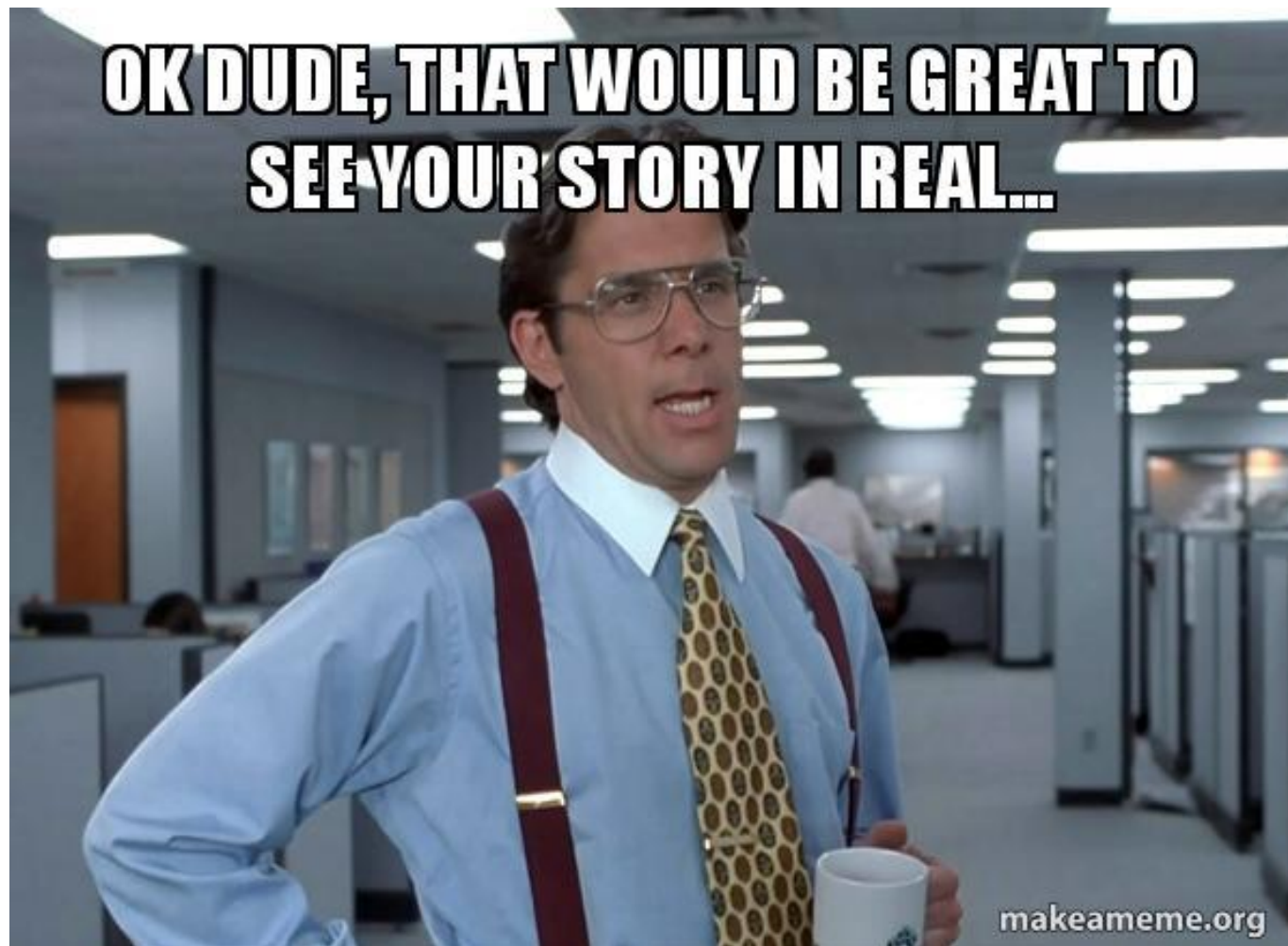
Roles

- ANONYMOUS** : Indicate that no authorization is needed
- BASIC** : Role affected to a standard user (lowest access right just above anonymous)
- ADMIN** : Role affected to an administrator user (highest access right)

Authorizations

Service	URI	Method	Role
ReadSingleMessage	/ {messageId}	GET	ANONYMOUS
ReadSingleMessage	/ {messageId}	GET	BASIC
ReadSingleMessage	/ {messageId}	GET	ADMIN
ReadAllMessages	/	GET	ANONYMOUS
ReadAllMessages	/	GET	BASIC

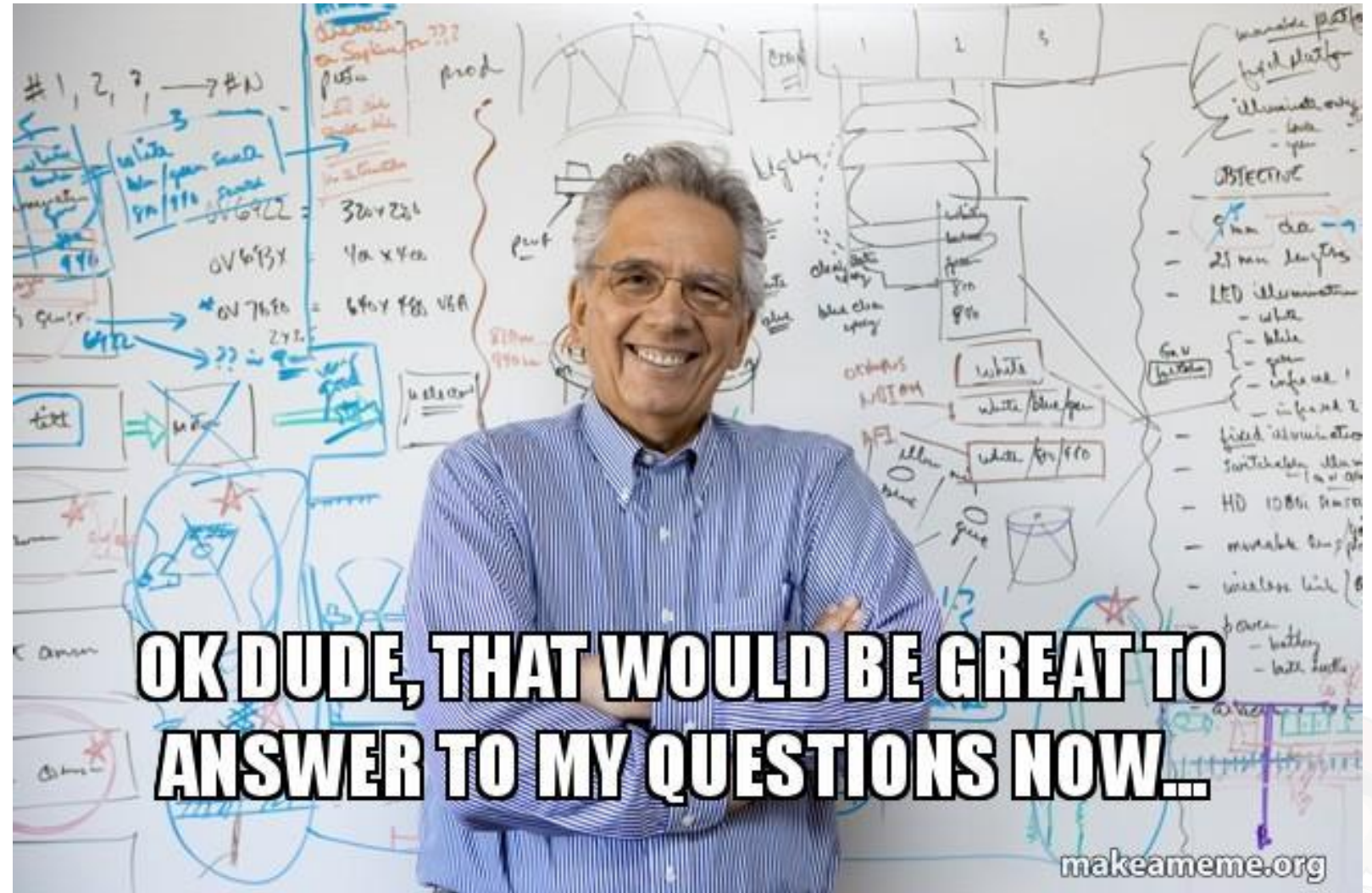
**OK DUDE, THAT WOULD BE GREAT TO
SEE YOUR STORY IN REAL...**



makeameme.org



Thanks you !



Demo source:

<https://github.com/righettod/voxxeddays-lux-2018>